PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Mesures cyber prioritaires et fiches ReCyF

03-1080 ANSSI - Mesures cyber préventives prioritaires et fiches ReCyF en pratique — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'authentification forte doit utiliser deux facteurs différents pour les administrateurs et la direction.
2. La sauvegarde hors ligne utilise le stockage à froid pour protéger les données critiques contre le chiffrement par rançongiciel.
3. Le ReCyF servira de socle à la réglementation cyber française pour la transposition de NIS 2.

Les 5 mesures cyber préventives prioritaires

Notion	À retenir
Le principe	Mettre en œuvre **5 mesures** essentielles à **court terme**, inscrites dans une démarche de cybersécurité **globale et de long terme**.
Renforcer l'authentification	Authentification forte à **deux facteurs différents** : mot de passe (ou tracé, signature) + **support matériel** (carte à puce, jeton USB, RFID), a minima un code reçu par un autre canal (**SMS**). Pour **administrateurs** (tous comptes : AD, applications, **cloud**) et **direction**.
Accroître la supervision	Superviser les événements journalisés ou centraliser les journaux (**VPN**, **contrôleurs de domaine**, **hyperviseurs**) pour détecter une compromission.
Sauvegarder hors ligne	Sauvegardes régulières ; déconnecter les plus critiques via **stockage à froid** (**disques externes** ou **bandes magnétiques**) et actualiser fréquemment.
Lister les services critiques	Inventorier et classer les services par **sensibilité** avec les métiers, en identifiant les **dépendances prestataires**.
Préparer la gestion de crise	Définir des **points de contact d'urgence** (sur papier) et des plans : **réponse**, **continuité informatique** et **reprise informatique**.

Synthèse des fiches ReCyF

Notion	À retenir
La collection	5 rubriques (**Défense**, **Protection**, **Gouvernance**, **Résilience**, **Obligations NIS 2**). Destinée au **public technique**. Un repère distingue les passages pour **entités essentielles** vs **toutes les entités**. Les fiches éclairent le ReCyF **sans s'y substituer**, ni prescriptives ni exhaustives.
La fiche Administration	Objectif : action **légitime**, depuis des **comptes/ressources dédiés**, et **attribuable de façon univoque**. Repose sur la maîtrise des **comptes/privilèges** et la **séparation/cloisonnement** des ressources.
La fiche Architectures sécurisées	Vise à **prévenir**, **détecter** et **remédier** aux intrusions. Utilise le **cloisonnement** (réduit exposition/latéralisation), le **filtrage** (flux nécessaires/visibilité) et la **sécurité des accès distants**.

Pièges et confusions

- ⚠ Confondre les 5 mesures prioritaires avec le nombre de rubriques des fiches ReCyF
- ⚠ Croire que les fiches ReCyF sont prescriptives
- ⚠ Penser que les fiches ReCyF remplacent le référentiel
- ⚠ Oublier que l'authentification renforcée des administrateurs inclut aussi leurs comptes dans le cloud
- ⚠ Ne pas déconnecter les sauvegardes critiques, les exposant ainsi au rançongiciel

Sigles et définitions

Authentification forte	Nécessite deux facteurs d'authentification différents
Sauvegarde hors ligne	Sauvegarde déconnectée du système d'information
Stockage à froid	Conserve des données sur des supports non connectés en permanence
ReCyF	Référentiel cyber France ou Référentiel français de cybersécurité
EE	Entités essentielles régulées par la directive NIS 2
EI	Entités importantes régulées par la directive NIS 2
Cloisonnement	Mesures de sécurité entre différentes zones pour limiter l'exposition et la propagation
Latéralisation	Déplacement d'un attaquant d'une zone compromise vers d'autres zones du même système

Auto-test

1. Combien de mesures cyber préventives prioritaires l'ANSSI préconise-t-elle ?
2. Quel est l'objectif du cloisonnement ?
3. Quels supports peuvent être utilisés pour le stockage à froid ?
4. Que doit-on définir pour la gestion de crise ?
5. À quoi sert le filtrage ?

Réponses : **1.** 5 · **2.** Limiter l'exposition et la propagation d'un attaquant · **3.** Disque externe ou bande magnétique · **4.** Points de contact d'urgence et plans de réponse, continuité et reprise · **5.** Limiter les communications entre zones aux seuls flux nécessaires et autorisés

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.